# SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Özgür Kerem Öncel | Grup Gece 4/B · No: 225541072 | Tarih 09.11.2026

**Kavram: SBOM** = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

## Verilen zafiyet kaydı

| | |
|---|---|
| **Bileşen** | Component X (PLC firmware kütüphanesi)→ bu makinede: robot kontrolörü firmware kütüphanesi kabul edildi |
| **Sürüm** | 2.4 |
| **CVE** | CVE-XXXX-XXXX |
| **Önem** | Critical (CVSS 9.8) |
| **Yama** | Mevcut |

## Görev — karar akışı

1. **Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)**
   Var mı? SBOM'a bakılır — KÖR NOKTA: OPLOG/TARQAN için kamuya açık SBOM yok; robot kontrolörü, safety kontrolörü ve filo sunucusu için ayrı SBOM istenir. Sürüm? 2.4 tedarikçinin etkilenen aralığındaysa evet. Ulaşılabilir mi? Servis robot WLAN'ında açıksa C2'ye erişen herkes ulaşır. Üçü de sağlanıyorsa etkiler; CVSS 9.8 tek başına karar değildir.
2. **Üretimi hemen durdurur musunuz? Neden / neden değil?**
   Hayır, tüm depoyu durdurmayız; önce ulaşılabilirliği keseriz (C2 izin listesi, ilgili port kapatılır). Aktif istismar kanıtı varsa veya safety kontrolörü etkileniyorsa etkilenen robotlar kontrollü olarak güvenli duruma alınır; aktif istismarda üretici OPLOG'un CRA Md. 14 bildirim saati başlar (11.09.2026'dan beri yürürlükte).
3. **Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?**
   Önce test: üretimden ayrık test alanında tek test robotunda navigasyon (10 mm sapma), raf kaldırma/indirme, hız profili, acil stop ve durma mesafesi, filo haberleşmesi. Sonra 1 robotla pilot, ardından filo küçük gruplar halinde vardiya dışında; rollback imajı hazır.
4. **Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**
   SBOM–mimari eşleştirmesine bakılır: kütüphane safety kontrolöründe mi, hız/koruma alanı seçimini besleyen kodda mı? Sürüm notları ve değişen modüller incelenir. Etkiliyorsa yeniden doğrulama (durma mesafesi, koruma alanı, acil stop; EN ISO 13849-2) ve 2023/1230'a göre 'esaslı değişiklik' değerlendirmesi; etkilemiyorsa regresyon testi + gerekçe kaydı.
5. **Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**
   Açık servisi kapatmak veya yalnız filo sunucusu IP'sine izin vermek; robot WLAN'ında 802.1X cihaz kimliği; WLAN'da saldırı tespiti/izleme; mühendislik ve uzak erişimi varsayılan kapalı tutmak; insan bölgesinde hız limitini düşük tutup safety tarafında kilitlemek; risk kaydına 'yamasız — telafi edici önlemle kabul' satırı ve yeniden değerlendirme tarihi.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

**KARAR (Vulnerability Decision): Üretim topyekûn durdurulmaz; açığın robot ağına ulaşılabilirliği hemen kapatılır, yama test robotunda doğrulandıktan sonra dalgalar halinde uygulanır; safety kısmı etkileniyorsa yeniden doğrulama yapılmadan robot insanlı alana dönmez.**